

Vulnerability Assessment Report: Remote Production MySQL Database

Lead Cybersecurity Analyst: Matthew Abegyah

Target Environment: Remote Production MySQL Database Server

Standard & Framework: NIST SP 800-30 Rev. 1 (*Guide for Conducting Risk Assessments*)

Assessment Period: July 2026

Document Classification: Confidential / Internal Security Review

Contents

1.0 Executive Summary & Engagement Scope	3
1.1 Executive Summary	3
1.2 Target System Characterization	3
1.3 Assessment Scope & Boundary	3
2.0 Asset Criticality & Business Impact Analysis	3
2.1 Threat Vector Quantification	4
3.0 Risk Assessment Matrix (NIST SP 800-30 Rev. 1)	4
3.0.1 Risk Assessment Interpretation	5
4.0 Detailed Findings & Technical Analysis	5
4.1 Finding SEC-01: Direct Exposure of Database Port to Public Network Boundary	5
4.2 Finding SEC-02: Broad Access Scope & Absence of Strict IAM Segmentation	6
4.3 Finding SEC-03: Insufficient Audit Logging & Telemetry Integration	6
5.0 Strategic Remediation Roadmap	6
5.1 Network-Layer Isolation & Perimeter Hardening	6
5.2 Identity & Access Management (Administrative Controls)	6
5.3 AAA Security Framework (Operational Controls)	7
6.0 Conclusion	7

1.0 Executive Summary & Engagement Scope

1.1 Executive Summary

During the assessment period of July 15, 2026, an in-depth vulnerability assessment was conducted against the organization's remote production MySQL database infrastructure. The primary objective was to evaluate the perimeter security posture, network exposure, and authentication/authorization access controls protecting critical business data.

The assessment identified critical architectural deficiencies most notably, direct routability to the public Internet without perimeter isolation. Under **NIST SP 800-30 Rev. 1** criteria, this configuration exposes the asset to sustained automated external exploitation, threatening regulatory compliance (GDPR, PCI-DSS) and core operations. Immediate engineering countermeasures, including network segmentation, Zero-Trust access control, and centralized security telemetry, are required

1.2 Target System Characterization

- **Host Operating System:** Linux Enterprise Server
- **Memory Allocation:** High-performance multicore CPU; 128 GB RAM
- **Target Service:** MySQL Enterprise Database Server (Default Listener: TCP Port 3306)
- **Network Interfaces:** Publicly routable IPv4 interface
- **Transport Encryption:** SSL/TLS enabled for active client-server transit

1.3 Assessment Scope & Boundary

- **Included:** Transport-layer accessibility, network ingress or egress boundaries, host-level access control mechanisms, and Identity & Access Management (IAM) role assignments.
- **Excluded:** Disruptive automated denial-of-service (DoS) stress testing, physical perimeter penetration, and source-code reverse engineering of client applications.

2.0 Asset Criticality & Business Impact Analysis

The target MySQL server constitutes tier-1 critical infrastructure, serving as the authoritative data store for:

- **Sensitive Business Telemetry:** Three continuous years of historical transactional and revenue data.
- **Regulated Identity Data:** Customer Personally Identifiable Information (PII) and Sensitive Personally Identifiable Information (SPII).
- **Proprietary Business Logic:** Internal commercial analytics and competitive trade data.

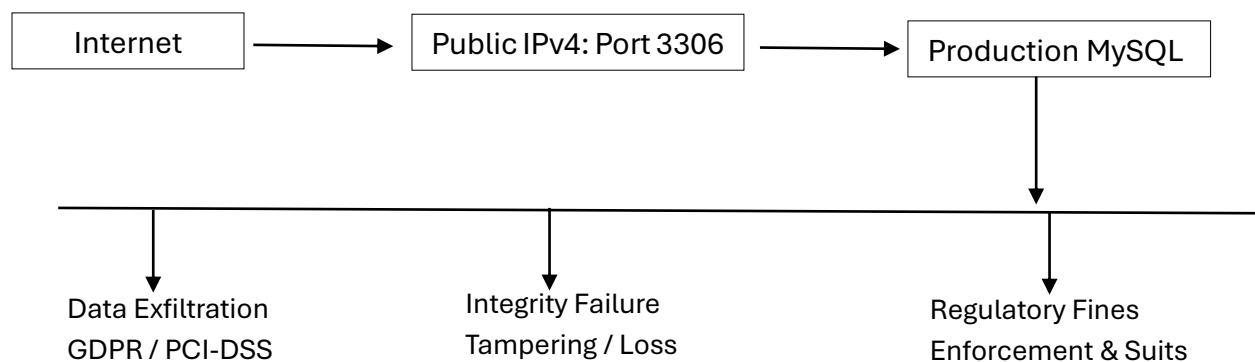


Figure 2.0 (Potential Threat Exposure)

2.1 Threat Vector Quantification

Direct exposure of relational database listeners to public CIDR blocks violates standard defensive architectures. Unfiltered public access enables:

1. **Automated Reconnaissance & Brute-Force Attacks:** Relentless credential stuffing and dictionary attacks against administrative accounts.
2. **Protocol Zero-Day Vulnerability Exploitation:** Exploitation of unpatched daemon vulnerabilities prior to vendor patch dissemination.
3. **Severe Regulatory & Financial Penalties:** Non-compliance penalties under GDPR Article 32 (Security of Processing) and PCI-DSS Requirement 1 (Install and Maintain Network Security Controls).

3.0 Risk Assessment Matrix (NIST SP 800-30 Rev. 1)

This matrix evaluates potential threat sources, events, and their calculated risk levels based on the formula: ***Risk Level = Likelihood X impact (Severity)***

Scale interpretation: 1 = Low, 2 = Moderate and 3 = High

Risk Score Bands: 1-3 = Low, 4-5 = Moderate and 6-9 = High/Critical

Threat source	Threat event	Likelihood	Severity	Risk
Hacker (External Source)	Unauthenticated exploitation of port 3306; credential stuffing leading	3	3	9

	to mass exfiltration of PII/SPII.			
Employee (Internal Source)	Abuse of excessive global privileges (GRANT ALL) causing deliberate/accidental data corruption or leakage.	2	3	6
Third Party vendors	Supply chain compromise; persistent external backdoor leveraging shared or hardcoded remote access keys.	2	3	6
Customer	Application-layer directory traversal or session tampering traversing upward into direct backend database queries.	1	3	3

3.0.1 Risk Assessment Interpretation

This qualitative assessment uses the structured principles of the NIST SP 800-30 Rev. 1 framework to determine realistic likelihood and business impact scores. The four specific threat scenarios above were chosen due to the high exploitability caused by leaving the database open to the public internet for three years.

- **Likelihood Scores:** Weighted as "High" (3) for external hackers because an open MySQL port (TCP 3306) acts as a constant beacon for automated scanning tools and malicious scripts.
- **Severity Scores:** Uniformly rated as "High" (3) because the targeted asset lacks defense-in-depth isolation. Without these controls, a single successful exploit breaks data confidentiality, integrity, and availability all at once.

4.0 Detailed Findings & Technical Analysis

4.1 Finding SEC-01: Direct Exposure of Database Port to Public Network Boundary

- **Vulnerability Description:** The MySQL service binds globally with firewall rules permitting ingress traffic from any source over the public Internet.

- **Root Cause:** Absence of a demilitarized zone (DMZ) or dedicated private subnet isolation.
- **Exploitation Feasibility:** Trivial. Attack surface identification requires only standard port scanning utilities.

4.2 Finding SEC-02: Broad Access Scope & Absence of Strict IAM Segmentation

- **Vulnerability Description:** Remote database users utilize blanket wildcard hosts rather than tightly constrained CIDR/FQDN blocks, coupled with an absence of mandatory Multi-Factor Authentication (MFA) for administrative access sessions.
- **Root Cause:** Operational convenience prioritized over the Principle of Least Privilege (PoLP).

4.3 Finding SEC-03: Insufficient Audit Logging & Telemetry Integration

- **Vulnerability Description:** Query auditing and authentication failures are written locally without immutable off-host streaming to a centralized SIEM platform.
- **Root Cause:** Absence of centralized AAA (Authentication, Authorization, Accounting) telemetry pipelines.

5.0 Strategic Remediation Roadmap

To protect the database server and secure access for remote workforce, the following multi-layered security engineering strategy should be implemented:

5.1 Network-Layer Isolation & Perimeter Hardening

- **Revoke Direct Routing:** Reassign the database server's network adapter to an isolated private subnet without public IP binding.
- **Enforce Transit Security Gates:** Route all remote operations through an enterprise Zero-Trust Network Access (ZTNA) broker or IPsec/WireGuard VPN gateway with strict posture checking.
- **Host-Based Packet Filtering:** Restrict internal traffic via iptables or ufw to whitelist only authorized application server IPs:

5.2 Identity & Access Management (Administrative Controls)

- **Enforce Least Privilege (PoLP):** Revoke all universal wildcard access. Bind administrative privileges to named identities and specific static hosts:
- **Mandatory MFA on Ingress Nodes:** Enforce hardware token or TOTP-based Multi-Factor Authentication across all administrative jump-boxes and VPN entry points prior to internal routing.

5.3 AAA Security Framework (Operational Controls)

- **Comprehensive Query Auditing:** Enable the MySQL Enterprise Audit plugin or server audit extension to record data manipulation language (DML) and data definition language (DDL) events.
- **SIEM Pipeline Integration:** Forward operational audit trails in real time via secure syslog into centralized monitoring tools (such as Splunk or Google SecOps).
- **Behavioral Detection Rules:** Build and deploy detection use cases within the SIEM to flag:
 1. Mass record extractions exceeding standard operational baselines.
 2. High-frequency authentication failures across short intervals (potential brute-force).
 3. Administrative query execution outside standard maintenance windows.

6.0 Conclusion

The exposed state of the remote MySQL production instance represents an unacceptable operational and compliance risk. Implementing network perimeter isolation, enforcing least-privilege access, and enabling continuous SIEM monitoring mitigates the external attack surface while maintaining secure, auditable access for legitimate administrative personnel.

Report Finalized By: Matthew Abegyah, Lead Cybersecurity Analyst

Framework Version Reference: NIST SP 800-30 Rev. 1